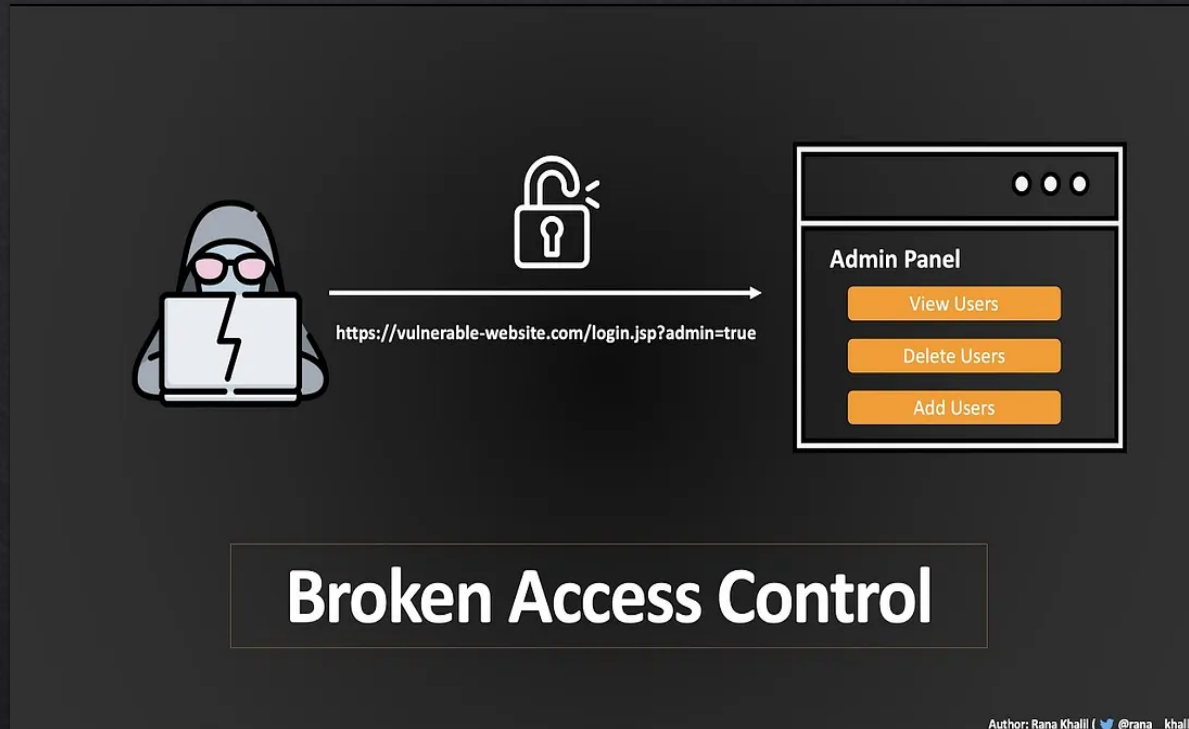


- A01:2025-Broken Access Control**
- A02:2025-Security Misconfiguration**
- A03:2025-Software Supply Chain Failures**
- A04:2025-Cryptographic Failures**
- A05:2025- Injection**
- A06:2025-Insecure Design**
- A07:2025-Authentication Failures**
- A08:2025-Software and Data Integrity Failures**
- A09:2025-Logging & Alerting Failures**
- A10:2025 -Mishandling of Exceptional Conditions**



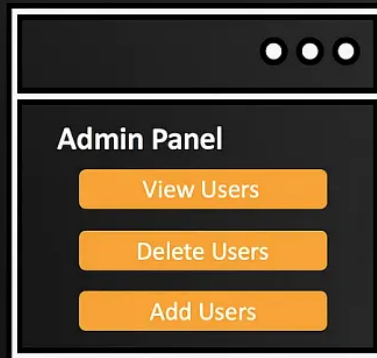
- ➔ **Bypassing Access Control Checks**
- ➔ **Privilege Escalation**
- ➔ **By Insecure Direct Object References (IDOR)**
- ➔ **Metadata Manipulation**
- ➔ **CORS Misconfigurations**
- ➔ **Exposure of Sensitive Information (from associated CWEs) :**

CWE-200: Sensitive info exposed to unauthorized users

CWE-201: Sensitive info exposed through transmitted data

CWE-918: SSRF enabling unintended backend access

CWE-352: CSRF enabling unauthorized actions



Security Misconfiguration

Author, Rana Khalil | @rana_kf



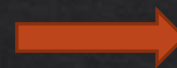
Missing or Improper Security Hardening



Unnecessary Features Enabled



Default Accounts or Credentials Left Unchanged



Disabled or Incorrectly Configured Security Features After Upgrades



Insecure Configuration of Application Components



Missing or Insecure Security Headers

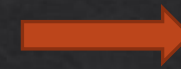


Software Supply Chain Failures

Author, Rana Khaili | Orana...612



Unverified Dependencies



Using Outdated, Unsupported, or Vulnerable Components



Missing or Weak Vulnerability Management



Insufficient Hardening and Weak Access Control



No Separation of Duties



Use of Untrusted or Unverified Third-Party Components



Delayed Patching and Slow Update Processes



Cryptographic Failures

Author, Rana Khalil | Orana__ki



Weak Algorithms



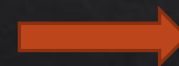
Improper Key Management



Failure to validate certificates or enforce secure transport (HTTPS/TLS)



Lack of encryption for sensitive data

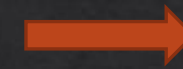


Incorrect implementation of cryptography



Injection Vulnerability

Author: Rana Khalli | [Twitter](#)



Lack of Input Validation



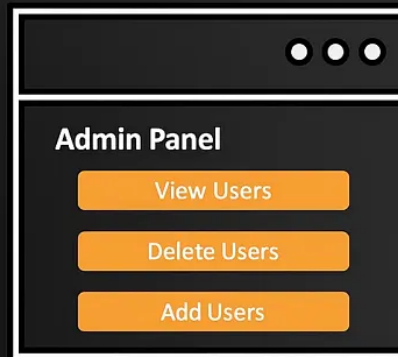
Unsafe Dynamic Queries



Unsanitized ORM Input



Dangerous Data Concatenation



Insecure Design

Author: Rana Khali | [Twitter](#)

- ➔ **Lack of Threat Modeling**
- ➔ **Absence of Security Requirements**
- ➔ **No Business Risk Profiling**
- ➔ **Inadequate Secure Design Practices**
- ➔ **Weak Development Lifecycle**
- ➔ **Poor Documentation of Flows & Controls**



• • •

Login

Username

Password

Login

Authentication Failures Vulnerability

Author: Rana Khalli |



Weak Password Policies



**Insecure Password Recovery
Mechanisms**



**Missing or Weak Multi-Factor
Authentication**



Exposed Session Identifiers



Session ID Reuse



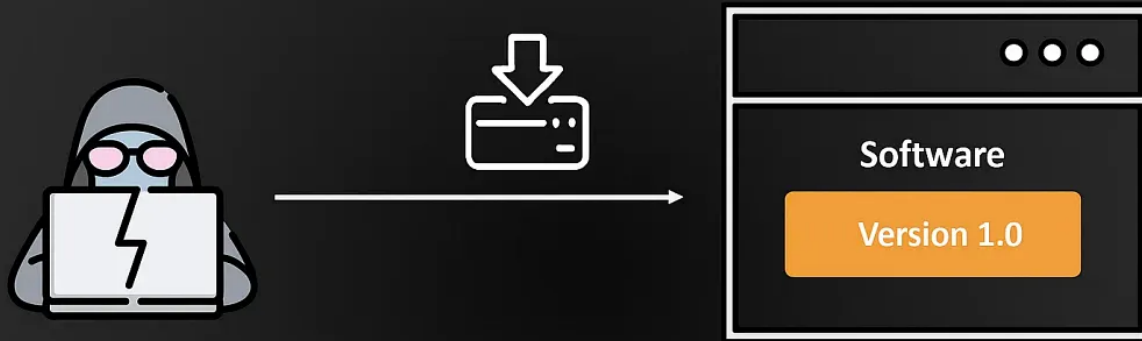
Poor Password Storage Practices



Improper Session Termination



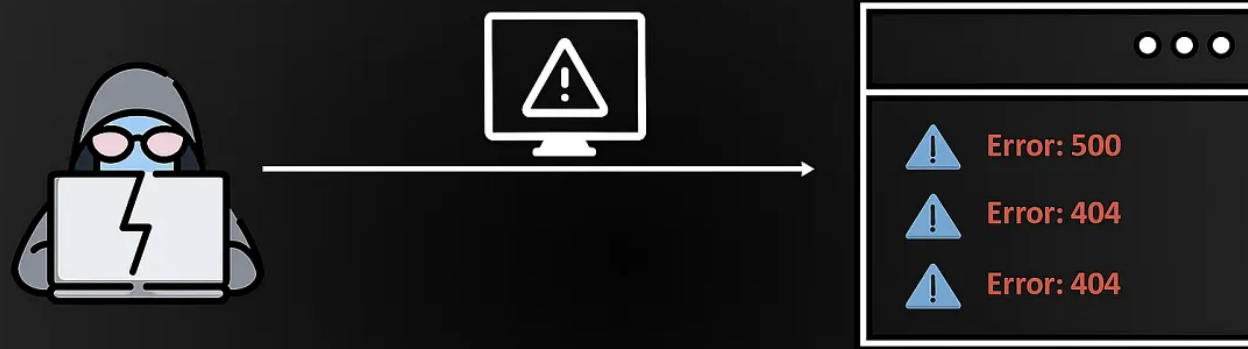
Force Browsing



Software and Data Integrity Failures

Author: Rana Khalil (@rana_)

- ➡ **Using Untrusted Code or Dependencies**
- ➡ **Unsafe Auto-Update Mechanisms**
- ➡ **Missing Integrity Verification**
- ➡ **Compromised Libraries**
- ➡ **Insecure Deserialization**
- ➡ **Insecure or Weak CI/CD Pipeline Security**



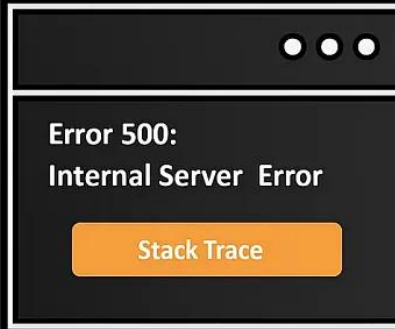
Logging & Alerting Failures

Author: Tiana Khali | 

- ➡ **Insufficient Logging**
- ➡ **Lack of Monitoring**
- ➡ **Poor Log Management**
- ➡ **Ineffective Alerting Systems**
- ➡ **Logging Sensitive Data**

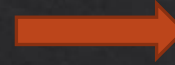


<https://vulnerable-website.com/search?q=%u820w>



Mishandling of Exceptional Conditions

Author: Rans Khalli | 



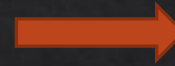
Poor or Late Error Handling



Missing or Weak Input Validation



Logic and State Handling Flaws



Missing Centralized Exception Handling